

가상기관 개인정보 처리지침

가상기관 규정 제2027-1호 · 2027. 1. 1. 시행

제1조(목적)

- ① 이 지침은 가상기관(이하 "기관"이라 한다)이 처리하는 개인정보를 안전하게 관리하고 정보주체의 권리를 보호하기 위하여 필요한 사항을 정함을 목적으로 한다.
- ② 개인정보의 처리에 관하여 다른 규정에 특별한 정함이 있는 경우를 제외하고는 이 지침에서 정하는 바에 따른다.

제2조(정의)

- ① "개인정보"란 살아 있는 개인에 관한 정보로서 성명, 연락처 등을 통하여 특정 개인을 알아볼 수 있는 정보를 말한다.
- ② "처리"란 개인정보의 수집, 생성, 저장, 이용, 제공, 파기 등 개인정보를 다루는 일체의 행위를 말한다.
- ③ "개인정보파일"이란 개인정보를 쉽게 검색할 수 있도록 일정한 규칙에 따라 체계적으로 배열하거나 구성한 개인정보의 집합물을 말한다.
- ④ "개인정보 처리시스템"이란 데이터베이스 시스템 등 개인정보를 처리할 수 있도록 체계적으로 구성한 시스템을 말한다.

제3조(적용 범위)

- ① 이 지침은 기관의 모든 임직원과 기관의 업무를 수행하는 외부 인력에게 적용한다.
- ② 이 지침은 전자적으로 처리되는 개인정보뿐 아니라 서면 등 비전자적 형태로 처리되는 개인정보에도 적용한다.

제4조(개인정보 보호책임자)

- ① 기관장은 개인정보 처리에 관한 업무를 총괄하여 책임질 개인정보 보호책임자를 지정한다.
- ② 개인정보 보호책임자는 개인정보 보호계획의 수립과 시행, 처리 실태의 점검, 정보주체의 불만 처리, 내부 교육 등의 업무를 수행한다.
- ③ 기관은 개인정보 보호책임자의 성명과 연락처를 기관 홈페이지 등에 공개하여 정보주체가 쉽게 확인할 수 있도록 한다.

제5조(개인정보의 수집·이용)

- ① 기관은 업무 수행에 필요한 최소한의 개인정보만을 적법하고 정당하게 수집한다.
- ② 개인정보를 수집하는 경우에는 수집 목적, 수집 항목, 보유기간을 정보주체에게 알리고 동의를 받는다.
- ③ 수집 목적이 변경되는 경우에는 변경된 목적에 대하여 정보주체의 별도 동의를 받는다.

제6조(동의를 방법)

- ① 동의는 서면, 전자적 방법 등 정보주체의 의사가 명확하게 확인되는 방법으로 받는다.
- ② 동의를 받을 때에는 동의 없이 처리할 수 있는 정보와 동의가 필요한 정보를 구분하여 알린다.
- ③ 정보주체에게 동의를 거부할 권리가 있다는 사실과 동의 거부에 따른 불이익의 내용을 함께 알린다.

제7조(아동의 개인정보)

- ① 만 14세 미만 아동의 개인정보를 처리하는 경우에는 법정대리인의 동의를 받는다.
- ② 법정대리인의 동의를 받기 위하여 필요한 최소한의 정보만을 아동으로부터 직접 수집할 수 있다.

제8조(개인정보의 제3자 제공)

- ① 기관은 정보주체의 동의가 있거나 법령에 근거가 있는 경우에 한하여 개인정보를 제3자에게 제공한다.
- ② 개인정보를 제3자에게 제공하는 경우에는 제공받는 자, 제공 목적, 제공 항목, 보유·이용 기간을 정보주체에게 알린다.
- ③ 제3자 제공 내역은 제공대장에 기록하여 관리한다.

제9조(개인정보 처리의 위탁)

- ① 기관은 개인정보 처리 업무를 위탁하는 경우 안전조치에 관한 사항이 포함된 문서로 계약을 체결한다.
- ② 위탁하는 업무의 내용과 수탁자를 기관 홈페이지 등에 공개한다.
- ③ 수탁자가 위탁받은 업무를 제3자에게 다시 위탁하려는 경우에는 기관의 사전 승인을 받도록 한다.

제10조(개인정보의 보유기간)

- ① 개인정보는 수집 시 정보주체에게 고지한 보유기간 또는 법령에서 정한 기간 동안만 보유한다.
- ② 부서별 개인정보파일의 보유기간은 개인정보파일 대장에 기록하여 관리하고, 대장은 연 1회 이상 현행화한다.

제11조(이용내역의 통지)

- ① 기관은 법령에서 정하는 경우 개인정보의 이용내역을 정보주체에게 주기적으로 통지한다.
- ② 통지는 전자우편 등 정보주체가 확인하기 쉬운 방법으로 하고, 통지 이력을 기록으로 남긴다.

제12조(개인정보의 파기)

- ① 기관은 보유기간이 경과하거나 처리 목적이 달성된 개인정보를 5일 이내에 파기한다.

- ② 전자적 파일 형태의 개인정보는 복구할 수 없는 방법으로 영구 삭제하고, 서면에 기록된 개인정보는 파쇄 또는 소각의 방법으로 파기한다.
- ③ 파기를 시행한 때에는 파기 일시, 파기 대상, 파기 방법을 파기대장에 기록하고 개인정보 보호책임자의 확인을 받는다.

제13조(정보주체의 권리 보장)

- ① 정보주체는 기관이 처리하는 자신의 개인정보에 대하여 열람, 정정, 삭제, 처리정지를 요구할 수 있다.
- ② 기관은 권리 행사 요구를 접수한 날부터 10일 이내에 조치 결과를 정보주체에게 통지한다.
- ③ 권리 행사의 방법과 절차는 개인정보 처리방침에 구체적으로 안내한다.

제14조(개인정보 처리방침)

- ① 기관은 개인정보 처리방침을 수립하여 기관 홈페이지에 지속적으로 공개한다.
- ② 처리방침에는 처리 목적, 처리 항목, 보유기간, 제3자 제공, 처리 위탁, 정보주체의 권리와 행사 방법에 관한 사항을 포함한다.
- ③ 처리방침을 변경하는 경우에는 변경 사실과 시행 시기를 홈페이지에 공지한다.

제15조(접근 권한의 관리)

- ① 개인정보 처리시스템에 대한 접근 권한은 업무 수행에 필요한 최소한의 범위로 업무 담당자에 따라 차등 부여한다.
- ② 인사이동 등으로 담당 업무가 변경된 경우에는 지체 없이 접근 권한을 변경하거나 말소한다.
- ③ 접근 권한의 부여, 변경, 말소 내역을 기록하고 그 기록을 최소 3년간 보관한다.

제16조(접근통제)

- ① 개인정보 처리시스템에 대한 불법적인 접근을 차단하기 위하여 침입차단 기능을 갖춘 장비를 설치·운영한다.
- ② 외부에서 개인정보 처리시스템에 접속하는 경우에는 안전한 인증수단을 적용한다.
- ③ 일정 시간 이상 업무 처리를 하지 아니하는 경우 자동으로 접속이 차단되도록 조치한다.

제17조(개인정보의 암호화)

- ① 고유식별정보, 비밀번호 등 중요 정보는 안전한 암호 알고리즘으로 암호화하여 저장한다.
- ② 비밀번호는 복호화되지 아니하도록 일방향 암호화하여 저장한다.
- ③ 개인정보를 정보통신망을 통하여 송신하는 경우에는 암호화하여 전송한다.

제18조(접속기록의 보관 및 점검)

- ① 개인정보 처리시스템에 대한 접속기록을 1년 이상 보관·관리한다.
- ② 개인정보의 오·남용, 분실, 유출 등을 확인하기 위하여 접속기록을 월 1회 이상 점검한다.
- ③ 접속기록이 위·변조되지 아니하도록 별도의 저장장치에 백업하여 보관한다.

제19조(악성프로그램 방지)

- ① 악성프로그램의 침투를 방지하기 위하여 백신 소프트웨어 등 보안 프로그램을 설치·운영한다.
- ② 보안 프로그램은 자동 업데이트 기능을 사용하거나 일 1회 이상 최신 상태로 갱신한다.

제20조(물리적 안전조치)

- ① 전산실, 자료보관실 등 개인정보를 보관하는 물리적 장소에 대한 출입통제 절차를 수립·운영한다.
- ② 개인정보가 포함된 보조저장매체의 반출입을 통제하고 그 내역을 기록한다.

제21조(유출사고 대응)

- ① 기관은 개인정보 유출사고에 대비한 대응 절차를 수립하고 담당자와 보고 체계를 정한다.
- ② 개인정보의 유출을 인지한 경우 지체 없이 개인정보 보호책임자에게 보고하고 피해를 최소화하기 위한 조치를 시행한다.
- ③ 유출된 정보주체에게 유출 항목, 유출 경위, 대응 조치를 통지하고 법령에 따라 관계 기관에 신고한다.
- ④ 기관은 연 1회 이상 유출사고 대응 모의훈련을 실시하고 그 결과를 기록한다.

제22조(신규 시스템 도입 시 검토)

- ① 개인정보를 처리하는 시스템을 신규로 도입하거나 중요한 변경을 하는 경우에는 개인정보 침해 위험을 사전에 검토한다.
- ② 검토 결과 개선이 필요한 사항은 시스템 운영 개시 전에 조치한다.

제23조(개인정보 보호 교육)

- ① 기관은 개인정보를 취급하는 임직원을 대상으로 연 1회 이상 개인정보 보호 교육을 실시한다.
- ② 교육 계획과 실시 결과는 문서로 기록하여 보관한다.
- ③ 신규 임용자에 대하여는 임용 후 지체 없이 개인정보 보호 기본 교육을 실시한다.

제24조(수탁자에 대한 관리·감독)

- ① 기관은 수탁자가 개인정보를 안전하게 처리하는지를 연 1회 이상 점검한다.
- ② 수탁자의 개인정보 취급 인력에 대한 교육 실시 여부를 확인한다.
- ③ 점검 결과 미흡한 사항에 대하여는 시정을 요구하고 그 이행 여부를 확인한다.

제25조(가명정보의 처리)

- ① 가명정보를 처리하는 경우 원래의 상태로 복원하기 위한 추가 정보를 분리하여 별도로 보관한다.
- ② 가명정보의 처리 목적, 처리 기간, 파기 등에 관한 사항을 기록하여 관리한다.

제26조(영상정보처리기기의 운영)

- ① 영상정보처리기기를 설치·운영하는 경우 설치 목적, 촬영 범위, 관리책임자의 연락처를 기재한 안내판을 설치한다.
- ② 수집된 영상정보는 보관 기간이 경과하면 지체 없이 삭제한다.
- ③ 영상정보처리기기 운영·관리 방침을 수립하여 공개한다.

제27조(내부 점검)

- ① 개인정보 보호책임자는 이 지침의 이행 실태를 연 1회 이상 자체 점검한다.
- ② 점검 결과 발견된 미비점에 대하여는 개선 계획을 수립하여 조치하고 그 결과를 기관장에게 보고한다.

제28조(서면 개인정보의 관리)

- ① 개인정보가 기록된 서면은 잠금장치가 있는 안전한 장소에 보관한다.
- ② 서면을 열람하거나 외부로 반출하는 경우에는 관리대장에 기록한다.

제29조(위반 시 조치)

- ① 이 지침을 위반한 임직원에 대하여는 관련 규정에 따라 필요한 조치를 할 수 있다.
- ② 위반 행위가 재발하지 아니하도록 원인을 분석하고 재발 방지 대책을 수립한다.

제30조(지침의 개정)

- ① 이 지침은 관련 법령의 제정·개정 또는 기관 운영상 필요에 따라 개정할 수 있다.
- ② 지침의 개정 이력은 부록의 개정 이력표에 기록한다.

부칙

- ① 이 지침은 2027년 1월 1일부터 시행한다.
- ② 이 지침 시행 전에 처리된 사항은 이 지침에 따라 처리된 것으로 본다.